SCOPEWEAVE / EVIDENCE-FIRST VAPT

Security Assessment Report

Generated 09/11/2026, 21:32:32 · Remove the duplicates

1. Executive summary

This report contains 4 finding groups for the registered lab. 0 are source-rated High or Critical. Scanner observations, including those marked as false positives by the analyst, are retained for traceability. 2 local ZAP Spider crawl(s) with passive checks were recorded.

Duplicate summary · 4 workspace findings → 4 report entries. 0 extra entries combined during export.

Analyst review status for original findings · 4 Needs review · 0 Confirmed issue · 0 False positive

Remediation and retesting · Tracking records are included for 4 findings. Retest results are recorded by the analyst.

2. Scope and authorization

Assessment target	http://127.0.0.1:3000
Lab name	Local Juice Shop
Authorization basis	Self-owned local practice lab
Authorization reference	Self-owned local Juice Shop practice lab
Permitted actions	Web checks, Network diagnostics, Scanner result import, Layer review
Excluded paths	None
Scope registered	07/11/2026, 09:14:59

This is an analyst attestation; the app cannot independently verify local ownership or organizer approval. Imported findings are checked against the registered lab and excluded paths.

3. Methodology and integration matrix

ZAP uses a bounded Spider crawl and passive checks. Other connected scanners provide report files. The report groups recognized names for the same missing header at matching URLs. Identical evidence appears once with its original file and record references. One distinct tool is labelled Low agreement. Two or more are labelled Medium agreement.

Tool or feature	Status	Role or limit
OWASP ZAP	Used · local passive crawl	Bounded Spider crawl and passive checks; no active scan
Nmap	Import only	Approved XML report
Nessus	Import only	Approved .nessus report
OpenVAS / Greenbone	Import only	Approved XML report
Nikto	Import only	Approved XML report
Burp Suite	Import only	Approved XML issue export
Cross-tool agreement	Implemented · rule-based	Exact workspace matches and recognized header aliases on the same recorded URL. One tool = Low agreement. Two or more = Medium agreement.
Local Ollama planner	Available · optional local setup	On-device next-step suggestion; no scan started

Tool or feature	Status	Role or limit
Groq cloud analysis	Available · requires server key and consent	Source-linked AI interpretation; up to 10 finding summaries and 3 excerpts per finding; no scan started
Metasploit	Planned	No adapter or execution path
Imported evidence warning	Implemented	Pattern-based warning with optional exclusion from Groq review
Adaptive tool choices	Implemented · local guidance	Explain when to reuse evidence, import an approved report, or hold a tool.
Source line jump links	Planned	Jump from a finding to an exact imported-file line

Assessment plan

No plan was recorded for this report.

4. Evidence coverage and intake

A missing report means no file was recorded here. Coverage reflects the evidence available for this lab.

Tool	Latest status	Files	Linked finding groups	Details
Nmap	No report imported	0	0	No file from this tool is recorded for this lab.
Nessus	No report imported	0	0	No file from this tool is recorded for this lab.
OpenVAS / Greenbone	No report imported	0	0	No file from this tool is recorded for this lab.
Nikto	No report imported	0	0	No file from this tool is recorded for this lab.
OWASP ZAP	No in-scope records	3	4	9 record(s) did not match this lab scope.
Burp Suite	No report imported	0	0	No file from this tool is recorded for this lab.

Suggested next review Review finding: Content Security Policy (CSP) Header Not Set — OWASP ZAP reported Medium for F-BD492DEA. Its analyst status is Needs review. Check the source evidence and record your decision.

File import outcomes

File	Tool	Result	Accepted / excluded	Details	Reviewed
zap-recovered-20261107-214727-csp.json	OWASP ZAP	OUT OF SCOPE	0 / 9	File records reviewed against the registered lab scope.	09/11/2026, 18:25:00
zap-live-2026-11-09T12-54-33-084Z.json	OWASP ZAP	NO OBSERVATIONS	0 / 0	File format recognized; no reportable observations were present.	09/11/2026, 18:24:33
zap-live-2026-11-07T16-00-44-946Z.json	OWASP ZAP	IMPORTED	51 / 0	File records reviewed against the registered lab scope.	07/11/2026, 21:30:44

5. Findings and risk review

The project score is calculated only when the source supplied CVSS and the analyst entered all three 0–10 context values: **CVSS×0.4 + exposure×0.2 + exploitability×0.2 + asset impact×0.2**. It is a review aid; source severity stays visible and is never replaced.

Source severity distribution

Severity	Finding groups
Critical	0
High	0
Medium	2
Low	0
Info	2
Unknown	0

Analyst review priority distribution

Review priority	Finding groups
Review now	0
High review	0
Context review	0
Moderate review	2
Routine review	2
Needs context	0

Detailed findings and evidence traces

F-BD492DEA · Content Security Policy (CSP) Header Not Set · Medium

Affected asset http://127.0.0.1:3000

Cross-tool agreement 1 tool · Low agreement · Sources OWASP ZAP

Source CVSS Not supplied · **CVE** Not supplied · **CWE** 693

Weighted review score Not calculated · source CVSS or analyst score components are missing.

Review priority Moderate review — A source reported Medium severity. · Source confidence recorded.

Analyst context Exposure Unknown · Asset impact Unknown · Exploitability Unknown

Scanner validation Scanner-reported; unvalidated

Analyst finding review · Needs review · Recorded 09/11/2026, 18:27:03

Review reason njk

Review evidence hiu

Description Not supplied

Remediation Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

Remediation and retesting

Remediation status Not started

Remediation notes No fix notes recorded.

Retest status Retest not started

OWASP ZAP · OBSERVED IN IMPORTED REPORT

Content Security Policy (CSP) Header Not Set

Repeated evidence · 13 matching records shown in one evidence block.

Source asset http://127.0.0.1:3000
Reported Medium · CVSS not supplied · Confidence High
Scanner-reported; unvalidated

Parsed evidence text

No parsed evidence text supplied.

Source references

- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[2]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[3]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[20]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[21]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[26]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[28]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[30]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[31]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[32]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[33]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[45]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[46]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[49]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present

---

F-197B9EDE · Cross-Domain Misconfiguration · Medium

Affected asset http://127.0.0.1:3000

Cross-tool agreement 1 tool · Low agreement · Sources OWASP ZAP

Source CVSS Not supplied · **CVE** Not supplied · **CWE** 264

Weighted review score Not calculated · source CVSS or analyst score components are missing.

Review priority Moderate review — A source reported Medium severity. · Source confidence recorded.

Analyst context Exposure Unknown · Asset impact Unknown · Exploitability Unknown

Scanner validation Scanner-reported; unvalidated

Analyst finding review · Needs review · No review recorded

Description Not supplied

Remediation Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance). Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.

Remediation and retesting

Remediation status Not started

Remediation notes No fix notes recorded.

Retest status Retest not started

OWASP ZAP · OBSERVED IN IMPORTED REPORT

Cross-Domain Misconfiguration

Repeated evidence · 31 matching records shown in one evidence block.

Source asset http://127.0.0.1:3000

Reported Medium · CVSS not supplied · Confidence Medium

Scanner-reported; unvalidated

Parsed evidence text

No parsed evidence text supplied.

Source references

- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[1]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[4]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[5]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[8]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[9]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[10]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[11]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[12]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[13]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[14]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[15]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[17]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[22]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[23]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[25]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[27]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[29]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[34]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[35]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[36]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[37]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[38]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present

- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[39]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[40]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[41]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[42]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[43]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[44]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[47]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[48]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[50]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present

---

F-00D86C7F · Information Disclosure - Suspicious Comments · Info

Affected asset http://127.0.0.1:3000

Cross-tool agreement 1 tool · Low agreement · Sources OWASP ZAP

Source CVSS Not supplied · **CVE** Not supplied · **CWE** 615

Weighted review score Not calculated · source CVSS or analyst score components are missing.

Review priority Routine review — A source reported Info severity. · Source confidence needs review.

Analyst context Exposure Unknown · Asset impact Unknown · Exploitability Unknown

Scanner validation Scanner-reported; unvalidated

Analyst finding review · Needs review · No review recorded

Description Not supplied

Remediation Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.

Remediation and retesting

Remediation status Not started

Remediation notes No fix notes recorded.

Retest status Retest not started

OWASP ZAP · OBSERVED IN IMPORTED REPORT

Information Disclosure - Suspicious Comments

Repeated evidence · 3 matching records shown in one evidence block.

Source asset http://127.0.0.1:3000

Reported Info · CVSS not supplied · Confidence Low

Scanner-reported; unvalidated

Parsed evidence text

No parsed evidence text supplied.

Source references

- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[16]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[18]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present

- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[19]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present

---

F-41975EC8 · Modern Web Application · Info

Affected asset http://127.0.0.1:3000

Cross-tool agreement 1 tool · Low agreement · Sources OWASP ZAP

Source CVSS Not supplied · **CVE** Not supplied · **CWE** -1

Weighted review score Not calculated · source CVSS or analyst score components are missing.

Review priority Routine review — A source reported Info severity. · Source confidence recorded.

Analyst context Exposure Unknown · Asset impact Unknown · Exploitability Unknown

Scanner validation Scanner-reported; unvalidated

Analyst finding review · Needs review · No review recorded

Description Not supplied

Remediation This is an informational alert and so no changes are required.

Remediation and retesting

Remediation status Planned

Remediation updated 09/11/2026, 18:28:30

Remediation notes kn k,n lkn l

Retest status Retest not started

OWASP ZAP · OBSERVED IN IMPORTED REPORT
Modern Web Application
Repeated evidence · 4 matching records shown in one evidence block.
Source asset http://127.0.0.1:3000
Reported Info · CVSS not supplied · Confidence Medium
Scanner-reported; unvalidated
Parsed evidence text

No parsed evidence text supplied.
Source references

- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[6]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[7]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[24]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present
- File zap-live-2026-11-07T16-00-44-946Z.json · Report reference site[1]/alert[51]/instance[1] · Time 07/11/2026, 21:30:44 · Scanner timestamp when present

---

6. Approvals and limitations

Human review decisions

- No human validation decisions recorded.

An approval records the analyst's decision only. It does not execute a validation.

Assessment limitations

- ZAP may miss routes, authenticated areas, and JavaScript-heavy behavior; passive checks do not test exploitability.
- Nmap, Nessus, Greenbone, Nikto, and Burp adapters only import reports; missing routes or assets may be absent.
- Scanner findings are not independently confirmed. Analyst-entered context is not independently verified.
- Ollama suggestions stay local. Groq analysis sends a bounded evidence summary to its cloud with explicit consent. The report records the provider used and any rule fallback.
- Groq analysis covers only the supplied summary subset. Valid source IDs do not verify the factual accuracy of AI interpretations; compare each explanation with source evidence.
- Local browser storage is not encrypted. Treat the device and exported reports as sensitive.

Confidential assessment material · Share only as authorized · ScopeWeave local prototype